S109 - Infor ERP LN (Baan) — Confluence Export

Alle 5 Seiten | Space: SITSEC | Stand: 17.03.2026

Inhaltsverzeichnis

S109 - Infor ERP LN (Baan)

Modification history

Modification history of the SDSK Template

Version	Status	Responsible	modifications / comments
1.00	2015	Markus Fiedeldei	Ursprungsdokument
2.00 - 2.13	2015	Stefan Küch	Anpassungen als Ergebnis des Praxistests
2.20	08.07.2016	Karin Dreher	Aufnahme Fachlicher Systemverantwortlicher
2.30	31.10.2016	Karin Dreher, Simon Allgäuer	Anpassung Versionierung, Abschnitt Risiko 9.1 Messgrößen für EWS und Auswirkung eingefügt und Erläuterung überarbeitet, 9.2 Risiko-Katalog/Restrisiken und 9.3 Maßnahmen überarbeitet, Anpassung von Abschnitt 10, Klarstellung Erforderlichkeit von Abweichungen nach oben
2.40	16.05.2017	Manfred Franz	Aufnahme KRITIS-Relevanz (Deckblatt) Aufnahme Software-Asset-Liste (Kap.5 + Anlage A)
3.00	09.01.2018	Karin Dreher	Anpassung DS-GVO, Rechtsgrundlage, Begriffe, Risiken aus Betroffenensicht, TOM
3.1	07.02.2018	Karin Dreher	Klassifizierungstabelle, Verweis Standard Backup-, Protokollierungs- und Löschkonzept, Freigabe CTO 7.02.2018
3.11	16.02.2018	Manfred Franz	Formatierungen und Tabellen-Nummerierung
3.12	bei Veröffentlichung	Manuel Joseph	Fortschreibung im Wiki, Anpassung Metadaten, ...
3.2		Karin Dreher	Änderung Datenfeldkatalog, Übernahme Kategorien 1&1 + Beibehaltung dort fehlender Kategorien, kleinere Überarbeitungen
3.21	02.12.2019	Christoph Neuendorf	Hinzufügen der Dokumentenfreigabe und des Freigabedatums (Release date, Released by), Entfernung des Metadatenfeldes Change date, da Confluence die Änderungen inklusive Datumsänderungen überwacht und speichert
3.22	25.05.2021	Anne Graurock	

			Anpassung der Risikobetrachtung aus Betroffenensicht (Werte Likelihood, Gesamtrisikowert)
3.3	21.10.2021	Manuel Joseph	Migration of Metadata by using the Metadata plugin with the set "STANDARDIZED DATA PROTECTION AND SECURITY CONCEPT"
3.4	19.07.2022	Anne Graurock	Anpassung an UI RL Löschkonzept in Abschnitt 8 (Löschverfahren, Protokollierung Löschung, Datenkategorien)

Modification history of the IT System

Version	Date	Responsible	modifications / comments
–	06.05.2015	Eduard Postrak	Lieferung der Inhalte
0.10	06.05.2015	Stefan Küch	Initiale Version aus erhaltenen Daten/ Interview
2.00	09.08.2016	Manfred Franz	▪ Vorlagenänderung und Systemverantwortlichen-Update ▪ Update Risiken
2.10	11.04.2018	Björn Junghans	Aktualisierung
3.0	21.03.2019	Björn Junghans	Update for GDPR and risk evaluation
3.1	07.05.2019	Manfred Franz	Update Risiko- und Maßnahmentabelle
3.2	07.04.2020	Björn Junghans	Update risk- and measure table
3.3.	16.04.2020	Björn Junghans	Update Klassifizierung der Risiken
3.4	07 May 2020	Unknown User (nbuivan)	Update TOM, Interfaces, MetaData, small corrections

3.4.1	07 May 2020	Unknown User (nbuivan)	Update Reasons for deviation downwards
3.5	03 Nov 2020	Julian Doege	Update Metadata, Chapter 4 Categories Users, Chapter 5 Components of IT Systems, Chapter 6 Protocols, Chapter 8 translations
3.6	24 Feb 2021	Eduard Postrak	Update 11 Data portability
3.7	04 Nov 2021	Julian Doege	Update Point 5 architecture diagram
3.8.	02 Nov 2022	Julian Doege	Changed SDSK owner from Eduard Postrak to Julian Doege
3.8	14 Dec 2022	Manuel Joseph	Yearly review
3.9	10 May 2023	Alexander Rödiger	Update Data and its deletion dates on behalf of Julian Doege
3.9.1	08 Feb 2024	Julian Doege	Yearly review
4	13 Feb 2025	Julian Doege	Change "Components of the IT systems"
4.1	13 Feb 2025	Julian Doege	Change "Architectural diagram"
4.2	13 Feb 2025	Julian Doege	Change "Communication Matrix"
4.3		Julian Doege	Update "Components of the IT Systems"

	17 Feb 2025		
4.4	26 Feb 2026	Tobias Rimmel	Content checked
4.5	02 Mar 2026	Tobias Rimmel	document correction and update

Document Information

Version	**4.5**
Document classification	**internal**
Document status	**approved**
Document owner	**Julian Doege**
Approved on	**Mar 02, 2026**
Approved by	**Tobias Rimmel**

Document - Metadata

SDSK ID	S109
SDSK System name	Infor ERP LN (Baan)
SDSK Version	4.3
SDSK Status	approved
SDSK Classification	internal
SDSK Owner	Julian Doege
SDSK Release date	Feb 08, 2023
SDSK Released by	Julian Doege Eduard Postrak

IT System - Metadata

SDSK Priority	1
SDSK Business Manager (Plan)	Julian Doege
SDSK Development Manager (Build)	Eduard Postrak
SDSK Technical Manager (Run)	Eduard Postrak
SDSK Confidentiality	confidential
SDSK Availibilty	high
SDSK Integrity (Authenticity)	very high
SDSK Data Protection Classification	2
SDSK Criticality of Business Process	2
SDSK KRITIS	No

* Data Protection Class according to data protection classes

1 Preface

To the reader

To make reading easier, especially when viewing multiple SDSKs, the following formats have been used:

Explanations and explanatory notes are as an instruction text and is only visible when wiki page is edited.

This is what the instruction text looks like

Static pages have been used to make all of the SDSKs and process descriptions more maintainable. For the reader this is not visible, but enables us to keep the important sections of the documents aligned and up-to-date.

All of the SDSKs include four subpages which are used for the content that is mostly worked on. This enables us to build custom reports from these pages.

To the author of the system

The extent of the description in this document should reflect the complexity of the IT system under consideration (number of components, interfaces) in an adequate manner and should be kept as short and precise as possible.

In the following, the term IT systems covers all systems (e. g. servers, network components, platforms, mobile and stationary IT and telecommunications terminals, telecommunications systems and the operating systems and applications running on them) that store, process or transmit information in electronic form. These typically consist of a number of computer systems or network elements with the same or similar purpose.

The exact definition of the considered IT system must be done by the responsible person. If you determine the scope to limited, this can lead to the fact that a large number of standardized data protection and IT security concepts have to be adapted in a project. On the other hand, if the scope of the IT system is too large, this can lead to the fact that changes have to be carried out very frequently and that some of these changes have to be carried out at the same time, which often leads to a considerable increase in complexity.

This document should be updated by the responsible person for each release upgrade, if necessary. An annual review is also established. The current SDSK process applies, which also governs the approval and risk management process.

2 Introduction

The Cronon GmbH operates on instruction from STRATO AG a INFOR LN system for the purpose of invoicing contractional services which STRATO offers to its customers.

Via a / few user interfaces the STRATO employees can manage the data in this system on the basis of a user authorization concept.

The system provided by Cronon includes the components application, program interfaces and database. The INFOR LN system includes a defined interface for all invoice relevant informantion for the customers of STRATO.

Via the INFOR LN system, the accounts payable and accounts receivable accounting is carried out for STRATO.

3 Operations & Development

Operations

Location of Components	Company, country, place of performance
Storage	Rechenzentrum der STRATO AG in Berlin

	(DB Backup: RZ Karlsruhe)
Server	Rechenzentrum der STRATO AG in Berlin (DB Backup: RZ Karlsruhe)

Operations of Components	Company, country, place of performance
Storage	Cronon GmbH, DE, Berlin
Backup / Restore	Cronon GmbH, DE, Berlin
Server	Cronon GmbH, DE, Berlin
Databases	Cronon GmbH, DE, Berlin
Application	Cronon GmbH, DE, Berlin
Client	
... further	

Development

Please specify here by whom (company & organizational unit) the development of the IT system takes place and from which location and country the development takes place.

Company / Organizational unit	ERP Consulting/ Entwicklung Cronon GmbH
Country	Germany
Place of performance	Berlin

4 Business process and data flow

Short description: Tasks, aim and purpose

Acquisition and processing of the billing-relevant customer master data.

Essential functions

Query of all accounting information for all STRATO customers via a graphical user interface, text-based Interfaces, processes, reports and programms for business process monitoring. Management of prices and fees for STRATO products as source. Dunning process up to the handover to the debt collector.

Records of the customer and contractual data. Creation of bookings and invoices based on this data.

Essential business processes

A STRATO customer triggers an order via the STRATO website. The product contains a package and various domains. In this business case the preliminary customer and order management system STRATOData receives datasets, which are persisted in several database tables.

- Creation of a new trading partner (customer)
- Creation of a new contract
- Creation of several contract items (one functions as main tariff of the contract and the other for the domains)
- New creation of payment methods and payment data for trading partners
- Create new customer account
- If these items have a start date, due dates are generated.
- Creation of an initial invoice for these started contract items
- Sending first invoice by email to the trading partner
- Transmission of collection data to house bank for the purpose of collection of the invoice amount

Categories of users of the IT system:

user groups (check as applicable)		Company and Unit	Access via internet (worldwide)	Access from Jump Server
Administrators	•	Administratoren der Cronon GmbH	VPN	
			VPN	

Account managers	•	Strato Customer Service GmbH		
Employees	•	Purchase, Controlling, Finance, Administration, Customer Service, HR, HiDrive, CTO, DC Ops, Service Desk	VPN	
External Service Providers	•			
External account manager	•	External Call Centre assigned by STRATO	VPN	
	•			

*Details about the administrative accesses via jump server? see S902 - Admin access systems

****** **Link Verfahrensdokumentation** *********

- Is the system managed/accessed by mobile computers?

5 Technical implementation

What hardware components does the IT system consist of?

Basically the IT system consists of server, storages, switches and routers

What software components does the IT system consist of?

As operating systems Suse Linux Enterprise, CentOS und Microsoft Windows Server are used. A management console runs on the IBM / Lenovo systems and storage management software runs on the storage management software. On the application server the INFOR ERP LN is running with a license server software. The databases are Oracle Database Manangement Systems.

What security functions does the IT system obtain from other IT systems, e. g. authentication?

SSL, Client Cert Authentication

What security functions does the IT system provide to other IT systems?

SSL, User/PW Credentials

The following architectural diagram shows the basic components of the system with their communication connections over networks (VLANs):

User Access Overview

Access to other Systems

Components of the IT systems

Following Components are in two virtualised environments (Cronon VMWare & STRATO Hyper-V Platform). Hardware in the table below are the Database Hosts for the Oracle application and the NetApp. This Hardware is managed from other departments

Components	Operations system	Applications	loca
Server Live 1	SLES	INFOR ERPLN	B
Server Live 2	SLES	INFOR ERPLN	B
Server Live 3	SLES	Database	B
Server Live 4	SLES	Database	B
Server Live 5	Windows Server	INFOR OS	B
Server Live 6	Windows Server	AD / DNS Server	B
Server Live 7	Debian	DNS Masque	B
Server Live 8	Debian	DNS Masque	B
Storage Live	NetApp	Daten	B
Server Live FinanceTool 1	CentOS	Java components FinanceTool / SOAP API to STRATO	B
Server Live FinanceTool 2	CentOS	Java components FinanceTool/ Webtool extern	B
Server Live FinanceTool 3	CentOS	Java components FinanceTool/ SOAP API to STRATO	B

Server Loadbalancer 1	CentOS	HA-Proxy (Cronon)	B
Server Loadbalancer 2	CentOS	HA-Proxy (Cronon)	B
Server Loadbalancer 3	CentOS	HA-Proxy (Cronon)	B
Server Loadbalancer 4	CentOS	HA-Proxy (Cronon)	B
Server Loadbalancer 5	CentOS	HA-Proxy (Cronon)	B
Server Loadbalancer 6	CentOS	HA-Proxy (Cronon)	B
Server Loadbalancer 7	CentOS	HA-Proxy (STRATO)	B
Server Loadbalancer 8	CentOS	HA-Proxy (STRATO)	B
Server Live 9	Windows Server	CIFS	B
Server Live 10	Windows Server	CIFS	B
Server Live 11	Windows Server	Database (SQL)	B
Server Live 12	Windows Server	Database (SQL)	B

* Caption

location: M=Missouri K = RZ Karlsruhe B = RZ Berlin P = Pascalstraße, Berlin R = Router location … empty = see chart	power: A = 1 power supply to RZ-circuit A+B = 2 power supply units on 2 separate RZ circuits A/B = redundant components of a cluster with 1 power supply each to different RZ circuits U = "small" UPS (not RZ) N = Normal (without UPS or similar) Mains:	network: A = single connection A+B = redundant connection to 2 switches (e. g. via active/passive failover links) A/B = redundant components of a cluster, each with 1 connection to different switches

Details about location, power and network ? see SDSK S901 - RZ-Facility

6 Communication matrix

Internet interface (publicly accessible interface):

Interface	DNS name	Public	Service	Components
none				

Component to component and system to system interfaces:

to → from ↓	Infor LN	DB Server	InforOS	AD	MS SQL	Concur	FinanceTool	Str
Infor LN		ORACLE (1521)		TCP 88 Kerberos UDP 123 NTP TCP 389 LDAP TCP 636 LDAPS TCP/ UDP 464 AD PWD Change TCP/ UDP 53 DNS			JAVA	SC HT tcp
DB Server	ORACLE			TCP/ UDP 53 DNS				OF
InforOS	[Infor] tcp/8445 tcp/8312 tcp/ 11600-12300 tcp/7150 tcp/512				tcp/ 1433			

	tcp/21 tcp/61616							
AD / DNS	UDP/53	UDP/53	UDP/53 TCP/ 636		UDP/ 53			
MS SQL								
Concur								
FinanceTool	JAVA							SO HT
StratoData	SOAP, HTTPS	ORACLE, SSH					SOAP, HTTPS	
OnBase							SOAP, HTTPS	
Webserver				TCP/ UDP 53 DNS		SOAP, HTTPS tcp/udp 111 tcp/udp 635 tcp/udp 2049 tcp/udp 4045-4049 tcp/udp 20048 tcp/22		tcp
~~HiDrive~~ **S3 -** **ionoscloud.com**								
kled								
C4WS								
Citrix								
Adyen								

EMS (STRATO Archiv)								
NGCS								
Dropsuite								
reports.paypal.com								
smtp.rzone.de								
packages.icinga.com								
Delta (Inkasso)								
Intrum (Inkasso)								
ActiveMQ								
Cronon LoadBalancer Frontend								
Cronon LoadBalancer Backend								
Strato LoadBalancer Backend								
KSB Finance Proxy								
BI Reporting								
Elekon TS								
Strato CIFS								
CIFS Elekon								
CIFS Innodox								

Caption

Caption - protocols			
Protocol	**Description**	**TCP/UDP-Port**	**Encrypted?**
FTP	File Transfer Protocol	20/TCP; 21/TCP	
HTTP	Hypertext Transfer Protocol	80/TCP	
HTTPS	Hypertext Transfer Protocol Secure	443/TCP	• (SSL/TLS)
SMTP	Simple Mail Transfer Protocol	25/TCP	
SSH	Secure Shell	22/TCP	•
NRPE	Nagios Remote Plugin Executor	5666/TCP	•
NFS	Network File System	111/TCP; 2049/UDP	
Oracle	Ora-Listener Port	1521/TCP	
JAVA	Java Portrange	60000-65535	
TCP_LIZ	TCP Port INFOR ERPLN License server	6005	
CIFS	Network Share	445	

The caption of the protocols should include any protocol that is used in the table component to component and system to system interfaces. Please adjust the list to the used protocols. A selection of protocols can be found here.

7 Roles

Hier bitte das Berechtigungskonzept STRATO ERP einfügen mit kurzer Beschreibung zum Inhalt der Verlinkung.

Roles of the application users

Note

Motivation: The minimum description of the role and assigned functions makes it easier to identify the difference in similar roles and reduces the risk of incorrectly assigned rolls. If possible, role names should be chosen that indicate the associated rights. This makes it easier to validate role assignments during configuration.

No.	Role (denomination in the system)	User of the role	Description of the role	Data	Authorization	
					Read	Write[1]
RN1	accounting	accounting	Entry and processing of business transactions Accounting	Master data STRATO customers	X	X
RN2	Customer Contact Center	Customer Contact Center	Entry of credit note proposals and scanning of return mail	Master data STRATO customers	X	X
RN3	procurement	procurement	Entry and processing of orders (hardware, software, consumables)		X	X
RN4	controlling	controlling	Collection of data within the scope of the preparation of controlling reports		X	X
RN5	administration	administration	Processing of incoming and outgoing goods		X	X

1 All modifications (create, update, delete).

Roles of the application operators

Note

This table can sometimes only be filled at a later date and with the involvement of the responsible operator.

Motivation: Operational roles (maintenance, development, support, backup, report,...) must be an integrated part of the authorization concept. These roles usually have more extensive rights than the (strongly restricted) user roles. For example, operational roles are often able to influence or circumvent control and security mechanisms.

No.	Role	User of the system	Description	Data	Authorization	
					Read	Write[2]
ROp1	Root	administrators	Root rights on the corresponding systems enable the system administrator to maintain the system on which the relevant applications are operated.	all	X	X

2 All modifications (create, update, delete)

Roles of the technical user

Note

The following table can possibly be part of the interface documentation, in which case you should refer to the existing documentation.

Motivation: Technical user (technical / automated users - batch jobs for mass data processing, interfaces for data transfers,...) must be part of the authorization concept. These roles usually have more extensive rights than the (strongly restricted) user roles. For example, application user can influence or circumvent control and backup mechanisms.

Like all other roles, the technical user should be checked regularly. A person responsible for the technical user must be named (usually the person responsible for the operations).

No.	Name of the	Implementation in the system	Description of the	Data	Responsible person	Authorization

	automated user		automated user				
						Read	Write[3]
RTU1	bsp	bsp	local user account für batch processing of INFOR ERP LN	Various jobs of all tenants from 111 to 127	Baan-admin@Cronon.net	X	X
RTU2	oracle	oinstall	local user account for oracle database administration	various jobs	Baan-admin@Cronon.net	X	X
RTU3	Finstrat		Local user account for FinanceTool	FinanceTool data	Baan-admin@Cronon.net	X	X
RTU4	Nagios		Local user account for monitoring	Only authorization for NRPE client on specific processes and systemparameter for system monitoring purposes	Baan-admin@Cronon.net	X	X
RTU5	Noc_Cronon		local user account for network administration	no access to customer data etc.	Baan-admin@Cronon.net	X	X
RTU6	Tmxxx		local user account for bus component LN	Process user for database connection INFOR ERP LN	Baan-admin@Cronon.net	X	X
RTU7	sfxtCronon		sFTP user account	Collection of dedicated server consumption data from	Baan-admin@Cronon.net	X	X

				another server			

[3] All modifications (create, modify, delete).

Explanation

No.

Unique running number.

Role (denomination in the system)

Unique description of the role within the IT system, also known as the system role.

User of the role

Typical users (group) of this role within the application.

For employee roles, the typical organizational unit or the corresponding business process role (business role).

Description of the role / automated user

If possible, the resolution of the abbreviations of the role name and a description of the tasks, rights and obligations associated with the role in the context of the application.

Data

Assignment of data influenced by the role.

Responsible person

E-Mail of the responsible person.

8 Personal data in the IT system

In principle, the processing of personal data is only permitted for the initiation, fulfilment and termination of a business purpose (customer or employment relationship). The following is a detailed description and explanation of the purpose for which the personal data are processed in the relevant IT system and why this processing is absolutely necessary. If possible with justifiable effort, data must always be processed without reference to persons (anonymous, possibly pseudonymised). It is therefore also necessary to explain why this is not possible. The legitimate interest of the responsible party in the processing of data must be weighed up against the legitimate interest of the data subject, if the balancing of interests pursuant to Art. 6 I f) is the legal basis for data processing.

Legal base, Art. 6 GDPR

- consent of the data subject, Art, 6 I a) DSGVO
- Performance of contract, Art. 6 I b) DSGVO
- compliance with a legal obligation, Art, 6 I c) DSGVO
- to protect the vital interests of the data subject or of another natural person, Art, 6 I d) DSGVO
- performance of a task carried out in the public interest or in the exercise of official authority, Art, 6 I e) DSGVO
- Balancing of interests, Art. 6 I f DSGVO

Brief description of the purposes for which the personal data of the IT system is used:

For Billing purpose only

The personal data will be processed exclusively for the following purposes (please check all purposes, multiple entries possible):

For Billing and Invoicing

Purpose of processing[4]

- It is processed for operations, failure analysis, troubleshooting or for the purpose of data protection controls within the scope of Art. 32 GDPR
- Store and maintain employment or contractual relationship (e. g. application, prospective customers for products,...)
- Dept collection (justify legitimate interests!)
- Fulfilment of a contractual relationship (end customer contract)
    - Provision of services within the framework of a contractual relationship (e. g. provision of devices, platforms, services, services, internal payment research...)
    - Charging based on use
    - Accounting
    - Customer service
- Consulting/ market research/ advertising based on customer consent
- Provision of value-added services or services with additional benefits
- Logging of the processing of personal data according to Art. 32 GDPR
- Logging of the account and log data of employees and for input control according to Art. 32 GDPR

- Establishment of an employment relationship, fulfilment of the obligations arising from the employment relationship or termination of an employment relationship (employment or service relationship)
    - e. g. payroll, /time recording / vacation / business trips / social security /, work process, work organization,
    - Personnel development, training measures, etc.
    - Monitoring of the work performance

The following purposes must be agreed with the Data Protection Officer!

- Credit check/scoring
- Detection of misuse by customer
- Prevention of service fraud
- Detection of misuse by partners
- Detection of abusive conduct in the employment relationship
- Consulting/ market research/ advertising without consent, Art. 6 I f GDPR, balancing of interests
- Other

[4] The lawfulness of the processing of personal data is only given if, in addition to a permitted purpose of use (legal basis), the further data protection requirements (e. g. the security of processing in accordance with Art. 32 GDPR / technical and organisational measures - TOMs) are also complied with.

Data types & data field catalogue

Personal data is any information relating to an identified or identifiable natural person, i. e. a human being. The data which are displayed and/or evaluated during processing and use in connection with a person must also be documented here (this includes personal data)

With extensive and distributed databases it is possible to specify additional columns (for example: table).

Please take into account any protocol/logging data (e. g. from employees using or administering the IT system) in the following catalogue.

No.	Data type	Group of persons	Purpose of processing	Data category (see below)	Retention period with starting time/ - event	Deletion procedure a) regular b) special case	Deletion logging y/n

001	Customernumbers	customer	identification		11 years	is done by StratoData (OracleDB from Strato itself)	
002	Suppliernumbers	business partner	identification		11 years		
003	Persons of Contact	customer / business partner	correspondence		11 years		
004	Names	customer / business partner / employees	Legal traffic, identification		11 years	is done by StratoData (OracleDB from Strato itself)	
005	Employeenumbers	employees	identification		11 years	is done by StratoData (OracleDB from Strato itself)	
006	Adresses	customer / business partner	Legal traffic, identification		11 years	is done by StratoData (OracleDB from Strato itself)	
007	Bank details	customer / business partner	Debit notes / Credit Card Withdrawal / Bank Transfers		11 years		
008	E-Mail	customer / business partner / employees	Legal traffic, correspondence		3 months	is done by StratoData (OracleDB from Strato itself)	
009	Telephone	customer / business	correspondence		11 years	is done by StratoData	

		partner / employees				(OracleDB from Strato itself)		
010	Fax	customer / business partner	correspondence		3 months	is done by StratoData (OracleDB from Strato itself)		

Please check all boxes with corresponding data categories which are processed within the IT system. These are required for the records of processing.

- **Master data**
  personal data that are necessary to establish, accomplish or end a contract with an affected person (last name, first name, customer/ contract/ employee number, information about products, tariffs, invoices, history of contact, affiliation to company or department, etc.)
- **Contact Information**
  addresses, e-mail addresses, phone numbers, messenger IDS, etc.
- **Special categories of personal data** according to Art. 9 GDPR
  personal data indicating racial and ethnic origin, political opinion, religious or philosophical beliefs or trade union membership, as well as genetic data, biometric data for the unambiguous identification of a natural person, health data or data on sexual life or sexual orientation
- **Bank data**
  account number/IBAN, credit card information

- **Communication Content**
  Mails, SMS, voice messages etc.

- **Location data from network communication**
  cell-IDs of mobile phone connections, GPS coordinates, IP localisation, etc.

- **Traffic data**
  (excl. location data), which means information that necessarily occur for the establishment, accomplishment and ending of a communication process with TKS, such as communication processes referring to terminal identifications (A- and B-platform numbers), IP-addresses or device identifications (MAC-address, IMEI, etc.), information at the beginning or end of a communication process (like CDRs or Log-documents), etc.
- **Terminal device data**
  (excl. location data), which means information that are singled by terminal devices e.g. via mobile apps (Log-files, system status, user settings, browser information, etc.)

- **Usage data**
  information about type, scope, period of time and point in time of the usage of a web-based multimedia offer (websites, video offers, etc.)

- **User generated content**
  contents (documents, pictures, music data, etc.) that are intentionally produced by affected persons, data customers and/or users process in services or infrastructure provided by us

- **User-Account-Information**
  e.g. username, password, organisational information, etc.

- **Pseudonymous data**
  Personal data processed in such a way that, without recourse to additional information, it cannot be assigned to a specific person, provided that such additional information is kept separately and technical and organizational measures ensure that the data cannot be attributed to an identified or identifiable person.
- **Data processing on behalf as Processor**
  Personal data, that we process as a processor, e.g. for a group company
- **Data processing on behalf as Controller**
  Personal data, that is processed by a processor on our behalf, e.g. a service provider processes customer meta data
- **Other**

Person-related evaluations (evaluation catalog)

Final description and justification of all available personal evaluations with details of the recipients in the current version of the IT system. It must contain the data fields, the purpose of processing and information about the authorization roles assigned by the system for evaluation. Describe the purpose for which an evaluation may be used.

In addition to fixed evaluations, there are also variable or dynamic evaluations. From a data protection point of view, it is only permissible for a certain purpose to evaluate personal data. The earmarking principle must be adhered to.

Please note!

A search function or list display is also an evaluation, as is the display of data in a dialog application. The display of all data fields that can be accessed via the search function is absolutely necessary.

Please also consider evaluations of log data (e. g. from employees who use or administrate the IT system).

Overview of evaluations

The following evaluations are supported:

- Evaluations for the purpose of data backup or to ensure proper operation
- Evaluations are possible in the event of actual indications of a criminal offence involving data protection, the Legal & Compliance department and the works council in accordance with the applicable works agreements.
- Evaluation of account data for the purpose of authentication and authorization of the user.
- Other(s)

The following evaluations are also supported

No.	Description of the evaluation	Purpose of use	Download
001	Invoice/credit note	Billing	Yes
002	Transmission of incoming invoices	Transmission of incoming invoices from Saperion	Yes
003	customer master data	Basics for billing/payment collection/reminder/ taxation/other correspondence	Yes
004	supplier master data	Basics for order/payment/other correspondence	Yes
005	Open items Creditors	Management of open vendor items	Yes
006	Open items Debitors	Management of open debit items	Yes
007	employee master data	Approval process for credit memos	Yes
008	incoming goods data	Matching purchase orders/invoices	Yes
009	Collections/payouts of open items	Payments in Accounts Receivable Accounting	Yes
010	asset accounting	Asset management	Yes
011	Orders	Management of orders	Yes
012	VAT declarations	Determination of sales tax / input tax	Yes
013	payments	Payments in Accounts Payable Accounting	Yes

Import and export of personal data - interfaces

The following interfaces for user login and authorization management are planned

- Interfaces to a directory service such as LDAP or Active Directory for authentication and authorization management purposes
- Interfaces for the purpose of authentication with another authentication system such as a Web-SSO, PKI, etc.

All other interfaces are listed in the following two sections.

Overview of import interfaces

No.	Description of the interface	Partner system
001	SOAP API	STRATOData/ KSB STRATO
002	Synchronisations API	STRATOData database
003	OnBase	OnBase System STRATO
004	ELEKON	Direct debit/account statements
005	sFTP SPT	Dedicated Server SPT (DSData)
006	sFTP	Dropsuite
007	sFTP	Adcoach

General technical description of the import interfaces

Interface name (partner system)	001
Technical competence	STRATO AG, Storefront/ KSB
Purpose and descriptions of the transmitted data	Read invoice/ open items and re-start invoice dispatch
	SSL

Type of encryption	
Interface type	SOAP XML API
List of transferred data	invoice data, open items etc.

Interface name (partner system)	002
Technical competence	Cronon GmbH/ ERP Consulting
Purpose and descriptions of the transmitted data	Transmission of all customer and contract master data for invoicing purposes
Type of encryption	internal network, explicite IP clearing
Interface type	database interface (Oracle Trigger / SQL)
List of transferred data	refer to the list with the data fields from STRATOData database

Interface name (partner system)	003

Technical competence	STRATO AG
Purpose and descriptions of the transmitted data	document management especially for the invoices
Type of encryption	SSL. internal network
Interface type	XML
List of transferred data	Invoice documents, customer information

Interface name (partner system)	004
Technical competence	house bank
Purpose and descriptions of the transmitted data	ELEKON is a bank statement manager for automated processing of all bank statement positions
Type of encryption	none
Interface type	remote data transmission
List of transferred data	customer data: First name, surname, company, customer id,

	invoice number, IBAN, BIC, account number, bank code

Interface name (partner system)	005
Technical competence	Dediacted Server SPT
Purpose and descriptions of the transmitted data	Transmission of order-related traffic data of dedicated server to the INFOR ERP LN
Type of encryption	SSH
Interface type	sFTP
List of transferred data	Order information and chargeable traffic units

Interface name (partner system)	006
Technical competence	Dropsuite
Purpose and descriptions of the transmitted data	Transmission of order-related traffic data of dropsuite to the INFOR ERP LN
Type of encryption	SSH
Interface type	sFTP
List of transferred data	Order information and chargeable traffic units

Interface name (partner system)	007

Technical competence	Adcoach
Purpose and descriptions of the transmitted data	Transmission of order-related traffic data of Adcoach to the INFOR ERP LN
Type of encryption	SSH
Interface type	sFTP
List of transferred data	Order information and chargeable traffic units

Overview of export interfaces

No.	Description of the interface	Partner system
001	customer contact center	customer contact center
002	credit card deduction	Computop
003	Elekon	Elekon
004	SEPA direct debit	GenoCash
005	InkassoWebViewer	Inkasso Partner
006	FinanceTool	STRATO KSB/ Ordering
007	DMS interface	OnBase STRATO
008	trigger interface	STRATOData
009	e-mail interface	OFFICE IT Transfer customer
010	Nagios interface	dashboard
011	UStID-Check	Federal Central Tax Office

General technical description of the export interfaces

Interface name (partner system)	001
Technical competence	Cronon GmbH
Purpose and descriptions of the transmitted data	Entry of credit note proposals and scanning of return mail

Type of encryption	SSL
Interface type	GUI
List of transferred data	customer master data
Target country of transmission	Germany
Using the target system from...	Germany

Interface name (partner system)	002 (not used anymore)
Technical competence	Computop
Purpose and descriptions of the transmitted data	Payment via credit card
Type of encryption	SSL
Interface type	XML API
List of transferred data	pseudonymized payment information (credit card)
Target country of transmission	Germany / EU
Using the target system from...	Germany / EU

Interface name (partner system)	003
Technical competence	house bank
Purpose and descriptions of the transmitted data	ELEKON is a bank statement manager for automated processing of all bank statement positions

Type of encryption	none
Interface type	remote data transmission
List of transferred data	customer data: First name, surname, company, customer id, invoice number, IBAN, BIC, account number, bank code
Target country of transmission	Germany / EU
Using the target system from...	Germany / EU

Interface name (partner system)	004
Technical competence	house bank
Purpose and descriptions of the transmitted data	Electronic processing of domestic, SEPA and cross-border payments
Type of encryption	SSL
Interface type	remote data transmission
List of transferred data	customer data: First name, surname, company, customer id, invoice number, IBAN, BIC, account number, bank code
Target country of transmission	Germany
Using the target system from...	Germany

Interface name (partner system)	005
Technical competence	Delta Forderungsservice OHG, Intrum Financial Services GmbH, PAIR Finance GmbH
	Reminders, incidents for debt collection, debt collection

Purpose and descriptions of the transmitted data	
Type of encryption	SSL
Interface type	web interface
List of transferred data	customer and accounting information
Target country of transmission	Germany
Using the target system from...	Germany

Interface name (partner system)	006
Technical competence	Cronon GmbH
Purpose and descriptions of the transmitted data	Invoice information, invoice documentation, bookings, customer number, invoice number, open items
Type of encryption	SSL
Interface type	SOAP XML API
List of transferred data	Invoice information, invoice documentation, bookings, customer number, invoice number, open items
Target country of transmission	Germany
Using the target system from...	Germany

Interface name (partner system)	007

Technical competence	STRATO AG OFFICE IT
Purpose and descriptions of the transmitted data	document management especially for the incoices of STRATO AG
Type of encryption	SSL, internal network
Interface type	XML
List of transferred data	invoices, customer information
Target country of transmission	Germany
Using the target system from...	Germany

Interface name (partner system)	008
Technical competence	STRATO AG Commercial IT
Purpose and descriptions of the transmitted data	termination of contractual positions caused by cancellation, moneyback, cancellation due to non-payment, dunning, debt collection
Type of encryption	SSL
Interface type	SOAP XML API
List of transferred data	Data on the contract item, customer data, comment texts for a customer, date of contract termination, reason for cancellation, entries for dunning and/or collection incident.
Target country of transmission	Germany
Using the target system from...	Germany

Interface name (partner system)	009
Technical competence	STRATO AG OFFICE IT
Purpose and descriptions of the transmitted data	e-mails with invoice PDFs forwarding to the STRATO customers
Type of encryption	none
Interface type	E-Mail
List of transferred data	invoice documents, customer information
Target country of transmission	Germany
Using the target system from...	Germany

Interface name (partner system)	010
Technical competence	Cronon GmbH
Purpose and descriptions of the transmitted data	Reporting and monitoring of daily KPIs
Type of encryption	SSL
Interface type	web interface
List of transferred data	Number of invoices, Number of reminders, Number of collections, Number of open items, active ERPLN jobs
Target country of transmission	Germany

Using the target system from...	Germany

Interface name (partner system)	011
Technical competence	Federal Central Tax Office
Purpose and descriptions of the transmitted data	Verification of STRATO customer transmitted UStID
Type of encryption	SSL
Interface type	XML-RPC
List of transferred data	UstId_1, UstId_2, Firmenname, Adresse
Target country of transmission	Germany
Using the target system from...	Germany

Data types & data field catalog

Personal data is any information relating to an identified or identifiable natural person, i. e. a human being. The data which are displayed and/or evaluated during processing and use in connection with a person must also be documented here (this includes personal data).

No.

Unique running number.

Date field name

A descriptive description of a data field from which the content of the date can be inferred. Fields can be combined logically (e. g. street, house number, postal code, city = address or account number, bank, bank code = bank details) if it is generally clear which data fields are included..

Group of persons

Here, you must specify the person group to which the data is to be assigned.

- employees Personal data of data subjects to whom there is an employment relationship under labour law.
- Customers Personal data of customers in a contractual relationship exists.
- User Personal data of users of the services
- Business partners Personal data of business partners and suppliers with whom a contractual relationship exists. Personal data of affected persons who are shareholders of the company.
- Prospective customers All personal data that an interested party (not yet customer/ employee) has entrusted touns.
- Other third parties All persons who cannot be assigned to one of the above-mentioned groups of persons.

Purpose of processing

The purpose for which this data field was originally collected or why it is necessary for processing and use must be stated here.

Retention period

Here you must specify how long data is used before it is deleted or archived. Once the data is no more needed for the purpose of processing, the data must be deleted. Should the data have to be retained due to legal retention periods, the period of time after which they are archived (and thus blocked for previous use) and the period of time after which they are finally deleted must be indicated.

GDPR → https://eur-lex.europa.eu/eli/reg/2016/679/oj

9 Risk analysis & data protection impact assessment

The need for protection is to be determined by the information/system owner in accordance with the Directive. Later, it will be related to the risks documented in this document in order to assess possible countermeasures. Finally, the remaining residual risk must be identified, documented and verifiably accepted.

Methodology of risk assessment

Focus

- **System reference**: This is only about the risks directly related to the system. Aspects such as building security, power supply, etc. are dealt with in the "SDSK Cross-System Aspects".

- **Actual effective risk**: This chapter deals with the risks, probabilities and effects that still exist, taking into account the conditions and measures described in the previous chapters.

Likelihood
The likelihood describes how likely it is that a potential event can occur. Since it is virtually impossible to give an exact value as a percentage of a period of time, the probability is given here in the following steps:

Likelihood			
Value	**Risk**	**Frequency**	**Likelihood of data protection risks from the point of view of the data subject**
1	very low	All few years (2-10) or less frequent	theoretically possible
2	low	approx. once per year	practically possible, but not to be expected
3	medium	approx once per quarter	possible, incalculable
4	high	approx. once per month	probably
5	very high	daily / weekly	predominantly likely

Damage impact
The impact of the injury describes the direct or indirect damage assumed to the rights and freedoms of the person (s) concerned and to the undertaking if the potential event occurs. The following impacts shall be considered for the person concerned and the enterprise in each case and the assessment shall be carried out according to the levels listed below, whereby the impact value is only relevant for risk assessment from the perspective of the enterprise:
Evaluation aids/examples

Very low (1) / low (2)	medium (3)	High (4)/ very high (5)

Hardly perceptible / palpable but of minor importance	noticeable and painful, but well tolerated	hard to tolerate / existence-threatening
The event is not an issue for the next board meeting.	The event is possibly a topic in the next board meeting.	The event is certainly a subject of several board meetings in the near future.
Minor failures or malfunctions at a few customers	Significant failures or malfunctions at many customers	failures or malfunctions at all customers
The event is hardly noticed outside the company, or not at all.	The event may possibly find minor consideration in the press or on specific websites.	The event attracts attention in superregional leading media.
No or only minor effects for the data subject DSK 1 and 2 e.g. disclosure of address data of customers within the company	Damage that may affect social status or economic conditions DSK 2 and 3 e.g. publication of payment data	Damage, the extent of which is serious for the rights and freedoms of the data subject DSK 2 and 3 e.g. publication of passwords

DSK = Dataprotection classes: Datenschutzklassen

The assessment from the company's point of view must be made according to the following classification:

Impact			
Value	**Risk**	**STRATO Damage / EUR**	**Cronon Damage / EUR**
1		< 20.000	< 10.000

	very low		
2	low	< 100.000	< 50.000
3	medium	< 1.000.000	< 500.000
4	high	< 10.000.000	< 5.000.000
5	Very high	>/= 10.000.000	>/= 5.000.000

The actual risk can be determined from the combination of damage impact and probability of occurrence. Since countermeasures cost time and money, it makes sense to classify risks so that the available resources can be used in a targeted manner. In addition to increasing the effectiveness of risk management, a classification system focuses on the main risks. In addition, for various reasons (such as economic efficiency) it can also make sense not to document certain risks with (further) countermeasures and thus to accept them. However, this must be planned and documented comprehensibly.

Risks from the point of view of the data subjects

Please describe the risks which the data processing involves for the data subjects (customers, users, employees, ….)

					w TO
ID	Description	C*	I*	A*	likely
01	Personal data becomes public	x			

02	Hack / unauthorized access to personal data by third parties	x	x		
03	Loss of data (destruction, deletion)		x	x	
04	Corruption of data		x	x	
05	Access to data is not possible (temporarily)			x	
06	Customer gains access to another customers account (error in logical separtion)	x	x		
07	Missuse of data by employees / administrators	x	x		

* Confidentiality, Integrity, Availability

The total risk value is calculated by multiplying likelihood and impact.

As a rule, measures must be taken from a total risk value of 9 to reduce the risk (these measures are to be entered in the table below: Please indicate here which of the above-mentioned risks could be reduced by which measures and how much (probability and/or effect) they could be reduced. If no measures are evident or risk acceptance is present, please also state with brief justification.).

The risk assessment is carried out with TOM. If TOMs are planned but not implemented yet, the assessment should be made without TOM and the planned measures must be noted in the table below.

ID	status	Description (scenario + impact)	likelihood	impact	total risk value (likelihood x impact)
01	done	Different methods for Authentication/ Authorization for LN Application and LN Database/ Access audit	1	2	2

02	done	Prevent Access by Firewalling, Networking and API Configuration	1	2	2
03	done	DB Backup Strategie	1	2	2
04	done	Validation check of DB Backup making DB test restore/ recover	1	2	2
05	done	System monitoring/ early measure due to warning events	1	1	1
06	done	Prevented by Check in LN APIs	1	1	1
07	done	Two-man-rule due to risky tasks	1	2	2

Privacy impact assessment

A data protection impact assessment shall be carried out where any form of processing, in particular the use of new technologies, is likely to entail a high risk to the rights and freedoms of the data subject as a result of the nature, scope, circumstances and purposes of the processing operation. It is particularly necessary in the following cases:

- Systematic and comprehensive evaluation of personal aspects
- Extensive processing of special categories of data (see chapter 8)

The responsible person must consult the company data protection officer.

- A data protection impact assessment must be carried out
- A data protection impact assessment has been carried out and documented
- A data protection impact assessment must not be carried out

Risk catalogue & residual risks

The most important risks are listed below:

Key	Summary	T	Created	Updated	Due	Assignee	Reporter	P	Status	Resolution	Sub-Tasks

No issues found

For the classification of likelihood and impact please see the Risk analysis & data protection impact assessment.

Tips and hints

Create a (maximum) TOP-10 of the subjectively most important risks.

Or create a TOP-5 of the most likely risks first and then a TOP-5 with the greatest impact.

If the list threatens to become too long, discard all risks with low probability and low impact.

Possible measures leading to a reduction of the risk must be reported to the IT security officer via the reporting form.

The IT security officer and/or the CTO must be notified immediately of any new/recognized risks.

Risk measures

Safeguard measures can be divided into cause-related and effect-related measures for:

- Prevention of causes, e. g. by redundancies,
- limitation of damage, e. g. by monitoring / early detection, and
- Compensation for damages, e. g. by concluding an insurance contract.

The cause-related protective measures are aimed at reducing the incidence and making it more difficult to exploit weak points. Effect-related protective measures are intended to reduce the extent of damage caused by security incidents and to protect against damage.

Risk measures are actions for:

• Risk avoidance
Risk avoidance means refraining from risky transactions from the outset. However, the business unit will then also miss out on the opportunities associated with this business. In principle, every entrepreneurial activity is inherently associated with risks, so that risk avoidance can only be regarded as a suitable protective measure in a few individual cases.

• Risk reduction
Risk reduction is aimed at reducing the expected value of a loss. Since this expected value is made up of the estimated extent of damage, its probability of occurrence and the weak point used, it is also possible to reduce the extent of damage, the probability of occurrence or the simplicity of exploiting the weak point.

• Risk transfer
Risk is transferred by concluding contracts. In the case of insurable risks, insurance covers the risks for a fee (usually not possible in the case of reputational risks). It is also possible to stipulate contractual penalties, for example in the area of procurement. This possibility is limited in the case of KRITIS-relevant systems and where there are risks to the rights and freedoms of natural persons.

• **Risk acceptance**
Acceptance of risk means that risks are accepted because they cannot be managed by other protective measures or cannot be handled economically justifiable. Risks as a whole and residual risks can be accepted. Residual risk is defined as the hazard that still exists even if all theoretically possible safety precautions are applied or is to be borne by accepting the risk. This possibility is limited in the case of KRITIS-relevant systems and where there are risks to the rights and freedoms of natural persons.

Please indicate which of the above-mentioned risks could be reduced by which measures and how much (probability and/or effect) they could be reduced. If no measures are evident or risk acceptance is present, please also state with brief justification.

Key	Summary	T	Created	Updated	Due	Assignee	Reporter	P	Status	Resolution

No issues found

For the classification of likelihood and impact please see the Risk analysis & data protection impact assessment.

For each SDSK use the following templates:

- Risks from the point of view of the data subjects
- Risk catalogue & residual risks
- Measures

10 Technical and organizational measures

Taking into account the state of the art, the implementation costs and the nature, scope, circumstances and purposes of processing as well as the different likelihood of occurrence and severity of the risk to the rights and freedoms of natural persons, the person responsible and the contract processor shall take appropriate technical and organizational measures to ensure a level of protection commensurate with the risk (Art. 32 (1) sentence 1 GDPR).

In assessing the appropriate level of protection, particular account shall be taken of the risks associated with processing, in particular through destruction, loss or alteration, whether inadvertent or unlawful, or unauthorized disclosure of or unauthorized access to the personal data transmitted, stored or processed in any other way. (Art. 32 para. 2 GDPR)

For the system technical and organizational measures according to the current standard TOM are defined and implemented. Consideration of the above-mentioned criteria may result in stronger/additional measures being necessary or weaker protective measures being sufficient. These deviations shall be documented below. A deviation downwards must be justified.

No deviation from TOM.

Documentation of the deviations upwards and downwards

Req-No	Type of deviation (O=top / U=bottom)	
	↓	Description

Reason for deviation downwards:

Backup concept

Georedundancy Backup Concept/ System actually not establish

Logging concept

no deviations

Deletion concept

no deviations

For the backup, logging and deletion concept please consider the GDPR concepts

11 Data portability

Pursuant to Article 25 GDPR, the data subject has the right to receive the personal data concerning him/her which he/she has made available to the data controller in a structured, common and machine-readable format. It also has the right to have personal data transferred directly to another provider, if this is technically feasible.

This is made possible by the following measures:

All data can be exported via formatted exchange schemes (.txt or .cvs), excel export, xml based middleware, API´s etc.

Infor Statement GDPR:

LN_GDPR_SOD.pdf

This is not possible for the following data groups:

12 Data protection by design and by default

Pursuant to Article 25 of the GDPR, technical and organizational measures must be taken which are designed to effectively implement the data protection provisions of the GDPR and to protect the rights of natural persons. The default settings must be set in such a way that only personal data whose processing is necessary for the processing purpose (data protection-friendly default settings) is processed. This applies to the amount of personal data collected, the extent of processing, the storage period and the accessibility of the data.

This is made possible by the following measures*:*

Pseudonymization of data by processes in the application INFOR ERPLN. Possibiltiy for manual and automated processing to pseudonymize all relevant customer data.

S109 - Measures

Please indicate which of the above-mentioned risks could be reduced by which measures and how much (probability and/or effect) they could be reduced. If no measures are evident or risk acceptance is present, please also state with brief justification.

Key	Summary	T	Created	Updated	Due	Assignee	Reporter	P	Status	Resolution

No issues found

For the classification of likelihood and impact please see the Risk analysis & data protection impact assessment.

S109 - Risk catalogue & residual risks

The most important risks are listed below:

Key	Summary	T	Created	Updated	Due	Assignee	Reporter	P	Status	Resolution	Sub-Tasks

No issues found

For the classification of likelihood and impact please see the Risk analysis & data protection impact assessment.

Tips and hints

Create a (maximum) TOP-10 of the subjectively most important risks.

Or create a TOP-5 of the most likely risks first and then a TOP-5 with the greatest impact.

If the list threatens to become too long, discard all risks with low probability and low impact.

Possible measures leading to a reduction of the risk must be reported to the IT security officer via the reporting form.

The IT security officer and/or the CTO must be notified immediately of any new/recognized risks.

S109 - Risks from the point of view of the data subjects & persons concerned

Please describe the risks which the data processing involves for the data subjects (customers, users, employees, ….)

					w TO
ID	**Description**	**C***	**I***	**A***	**likely**
01	Personal data becomes public	x			
02	Hack / unauthorized access to personal data by third parties	x	x		
03	Loss of data (destruction, deletion)		x	x	
04	Corruption of data		x	x	
05	Access to data is not possible (temporarily)			x	
06	Customer gains access to another customers account (error in logical separtion)	x	x		
07	Missuse of data by employees / administrators	x	x		

* Confidentiality, Integrity, Availability

The total risk value is calculated by multiplying likelihood and impact.

As a rule, measures must be taken from a total risk value of 9 to reduce the risk (these measures are to be entered in the table below: Please indicate here which of the above-mentioned risks could be reduced by which measures and how much (probability and/or effect) they could be reduced. If no measures are evident or risk acceptance is present, please also state with brief justification.).

The risk assessment is carried out with TOM. If TOMs are planned but not implemented yet, the assessment should be made without TOM and the planned measures must be noted in the table below.

ID	status	Description (scenario + impact)	likelihood	impact	total risk value (likelihood x impact)
01	done	Different methods for Authentication/ Authorization for LN Application and LN Database/ Access audit	1	2	2
02	done	Prevent Access by Firewalling, Networking and API Configuration	1	2	2
03	done	DB Backup Strategie	1	2	2
04	done	Validation check of DB Backup making DB test restore/ recover	1	2	2
05	done	System monitoring/ early measure due to warning events	1	1	1
06	done	Prevented by Check in LN APIs	1	1	1
07	done	Two-man-rule due to risky tasks	1	2	2

S109 - Technical & organizational measures

Documentation of the deviations upwards and downwards

Req-No	Type of deviation (O=top / U=bottom)	
	↓	Description

Reason for deviation downwards: